

Cheat Sheet: CompTIA CySA+

Estimated duration: **15** minutes

Introduction

This cheat sheet focuses on the technical aspects of exam preparation, including essential topics, recommended skills, and study strategies to help you to streamline your study process and set you up for success when preparing for the **CompTIA CySA+** exam. You'll review the domains from the perspective of knowledge and skills you need to know as well as review practical tools and tips for a home lab.

What you will learn

In this cheat sheet, you will:

- Review the CySA+ exam domains, their core knowledge objectives and associated skills
- Identify essential tools required for hands-on practical skills for cybersecurity tasks
- List steps to gather study resources and prepare efficiently
- Create a study schedule to optimize your exam preparation

Review the exam domains and their core knowledge objectives

Let's first look at the critical domains of the CompTIA CySA+ exam. Each domain is essential for mastering cybersecurity practices and enhancing organizational security.

1.0 Security Operations

To effectively navigate the Security Operations domain, focus on the tasks associated with each listed concept. As you review this section remember to relate each bold term directly to a practical skill or task required for security operations.

1.1 System and network architecture concepts in security operations

This domain focuses on tasks associated with securing system and network architecture:

- **Log ingestion:** Managing time synchronization and configuring appropriate logging levels.
- **Operating system (OS) concepts:** Hardening the system, organizing file structures, and monitoring system processes.
- **Infrastructure concepts:** Implementing and securing virtualization, serverless environments, and containers.
- **Network architecture:** Designing and securing on-premises, cloud, or hybrid networks, ensuring zero trust and network segmentation.
- **Identity and access management:** Setting up MFA, SSO, and managing privileged access controls.
- **Encryption:** Configuring encryption protocols, including PKI and SSL inspection.
- **Sensitive data protection:** Safeguarding PII and CHD using data loss prevention (DLP) techniques.

1.2 Analyzing indicators of potentially malicious activity

The tasks associated with detecting and investigating malicious activity include:

- **Network-related:** Monitoring bandwidth, detecting rogue devices, and identifying unusual traffic patterns.
- **Host-related:** Investigating unauthorized software or processes and tracking changes in system resources such as memory or drive capacity.
- **Application-related:** Identifying unexpected behavior, such as new accounts or outbound communication.
- **Other threats:** Recognizing and responding to social engineering and suspicious links.

1.3 Tools and techniques for identifying malicious activity

The skills to focus on here involve using tools and techniques to uncover malicious actions:

- **Tools:** Capturing network traffic with Wireshark, analyzing logs with SIEM, and examining files using VirusTotal or sandboxing tools.
- **Techniques:** Analyzing command patterns, inspecting email headers, and monitoring user behavior for anomalies.

1.4 Threat intelligence and threat hunting concepts

The tasks here include gathering intelligence and actively hunting for threats:

- **Threat actors:** Identifying different threat actors, from APTs to insider threats.
- **Threat intelligence collection:** Gathering information from open sources such as blogs and CERTs, and closed sources such as paid feeds.
- **Threat hunting:** Collecting and analyzing IoCs and focusing on critical assets and misconfigurations.

1.5 Efficiency and process improvement in security operations

The tasks associated with improving efficiency in security operations involve:

- **Standardizing processes:** Automating repeatable tasks and coordinating teams to implement automation.
- **Streamlining operations:** Utilizing SOAR to orchestrate threat intelligence data and minimize manual effort.
- **Integrating technology and tools:** Integrating APIs and managing workflows through single-pane-of-glass solutions.

2.0 Vulnerability Management

The Vulnerability Management section focuses on implementing, analyzing, and responding to vulnerability-related tasks and scenarios. As you review each concept, think about the associated actions required to ensure effective vulnerability management.

2.1 Implement vulnerability scanning methods and concepts

When performing vulnerability scanning, consider these tasks:

- **Asset discovery:** Using map scans and device fingerprinting to identify devices on the network.
- **Special considerations:** Scheduling scans, optimizing performance, handling segmentation, and meeting regulatory requirements.
- **Internal vs. external scanning:** Executing both internal (inside the network) and external (from outside) vulnerability scans.
- **Agent vs. agentless:** Selecting between scanning methods that use agents and those that do not.
- **Credentialed vs. non-credentialed:** Choosing between scans with or without system credentials for more in-depth results.
- **Passive vs. active:** Performing passive scans that observe network traffic or active scans that probe systems directly.
- **Static vs. dynamic:** Conducting static code analysis or dynamic testing through reverse engineering and fuzzing methods.
- **Critical infrastructure:** Protecting OT, ICS, and SCADA systems by applying specialized scanning techniques.
- **Security baseline scanning:** Assessing systems against established security baselines and industry frameworks such as PCI DSS, CIS benchmarks, OWASP, and ISO 27000 series.

2.2 Analyze output from vulnerability assessment tools

Skills required to analyze vulnerability scan outputs:

- **Network scanning and mapping tools:** Using tools such as Angry IP Scanner or Maltego to discover network hosts and visualize connections.
- **Web application scanners:** Identifying vulnerabilities in web apps using Burp Suite, ZAP, or Arachni.
- **Vulnerability scanners:** Assessing systems with Nessus or OpenVAS to detect known vulnerabilities.
- **Debuggers:** Analyzing software behavior using tools such as Immunity Debugger or GDB.
- **Multipurpose tools:** Employing versatile tools such as Nmap, Metasploit, or Recon-ng for deeper network and vulnerability analysis.
- **Cloud infrastructure assessment tools:** Using Scout Suite, Prowler, or Pacu to secure cloud environments.

2.3 Analyze data to prioritize vulnerabilities

Key tasks for prioritizing vulnerabilities:

- **CVSS interpretation:** Understanding the severity of vulnerabilities based on factors such as attack vectors, complexity, and required privileges.
- **Validation:** Identifying true/false positives and negatives to ensure accurate reporting.
- **Context awareness:** Differentiating between internal, external, and isolated vulnerabilities.
- **Exploitability and weaponization:** Assessing how easily a vulnerability can be exploited.
- **Asset value:** Prioritizing vulnerabilities based on the importance of the affected assets.
- **Zero-day vulnerabilities:** Identifying and responding to zero-day threats promptly.

2.4 Recommend controls to mitigate attacks and software vulnerabilities

Tasks to mitigate vulnerabilities:

- **Cross-site scripting (XSS):** Preventing reflected and persistent XSS attacks.
- **Overflow vulnerabilities:** Addressing buffer, integer, heap, and stack overflow vulnerabilities.
- **Data poisoning:** Protecting against corrupted or malicious data inputs.
- **Broken access control:** Ensuring proper access controls are in place.
- **Cryptographic failures:** Securing data through robust encryption practices.
- **Injection flaws:** Preventing injection attacks such as SQL injection.
- **Directory traversal:** Blocking unauthorized file access.
- **Insecure design & misconfigurations:** Identifying and fixing security flaws in system design.
- **End-of-life components:** Ensuring that the organization replaces or secures outdated components.
- **Privilege escalation:** Preventing unauthorized users from gaining higher-level privileges.
- **Remote code execution (RCE):** Mitigating vulnerabilities that allow malicious code to run on systems.

2.5 Vulnerability response, handling, and management

Focus on managing and responding to vulnerabilities effectively:

- **Control types:** Implementing managerial, operational, technical, preventative, detective, and corrective controls.
- **Patching and configuration management:** Testing and rolling back patches, as necessary.
- **Maintenance windows:** Planning downtime for patching and updates.
- **Risk management principles:** Applying strategies to accept, transfer, avoid, or mitigate risk.
- **Attack surface management:** Reducing exposure by identifying and managing potential entry points.
- **Secure coding practices:** Ensuring input validation, output encoding, and session management to prevent vulnerabilities.
- **Secure SDLC:** Incorporating security throughout the software development lifecycle.
- **Threat modeling:** Identifying and mitigating potential threats during the design and development phases.

3.0 Incident Response and Management

To excel in the Incident Response and Management domain, focus on the tasks associated with each concept to understand and apply incident response processes effectively.

3.1 Explaining attack methodology frameworks

Understand and use these frameworks to analyze attack methods and improve security responses:

- **Cyber kill chains:** Study the stages of a cyberattack to break the chain and prevent breaches.
- **Diamond model of intrusion analysis:** Analyze attacks based on four core elements—adversary, infrastructure, capability, and victim.
- **MITRE ATT&CK:** Use this framework to map out attackers' tactics, techniques, and procedures (TTPs).
- **Open Source Security Testing Methodology Manual (OSSTMM):** Apply standardized methods to perform security testing.
- **OWASP testing guide:** Use this guide to ensure web application security testing aligns with best practices.

3.2 Performing incident response activities

Critical tasks revolve around detection, containment, and recovery:

- **Detection and analysis:** Identify indicators of compromise (IoCs), acquire and preserve evidence while maintaining the chain of custody, validate data integrity, and place data under legal hold if necessary. Analyze logs and data to identify the scope of the incident.
- **Containment, eradication, and recovery:** Contain the attack, assess its scope and impact, isolate affected systems, remediate issues, re-image compromised systems, and apply compensating controls to minimize further damage.

3.3 Preparing for and executing post-incident activity phases

Key tasks here focus on both proactive and reactive measures:

- **Preparation:** Develop an incident response plan, select the right tools, and create detailed playbooks for different scenarios. Conduct tabletop exercises and training to ensure team readiness. Prepare business continuity (BC) and disaster recovery (DR) plans to minimize downtime.
- **Post-Incident Activity:** Perform forensic analysis to collect and analyze evidence, conduct root cause analysis to identify the source of the attack, and document lessons learned to improve future incident responses.

4.0 Reporting and Communication

To succeed in the Reporting and Communication domain, focus on the tasks that ensure clear and effective communication throughout vulnerability management and incident response processes.

4.1 Explaining vulnerability management reporting and communication

Effective vulnerability management reporting involves:

- **Vulnerability management reporting:** Create detailed reports that cover vulnerabilities, affected hosts, risk scores, and mitigation strategies. Document recurrence patterns and prioritize vulnerabilities based on their severity.
- **Compliance reports:** Ensure reports align with regulatory requirements and standards.
- **Action plans:** Develop plans for patching, configuration management, and implementation of compensating controls. Ensure awareness, education, and training programs address emerging threats. Adapt to changing business requirements as needed.
- **Inhibitors to remediation:** Identify obstacles such as MOUs, SLAs, governance issues, and business process interruptions that can delay remediation efforts. Consider legacy or proprietary systems that might hinder mitigation.
- **Metrics and key performance indicators (KPIs):** Track trends, top vulnerabilities, critical issues, and compliance with SLOs.
- **Stakeholder identification and communication:** Communicate with relevant stakeholders about vulnerabilities and the steps to mitigate them.

4.2 Explaining incident response reporting and communication

Effective incident response relies on the following considerations:

- **Stakeholder identification and communication:** Identify key stakeholders and establish clear lines of communication throughout the incident response process.
- **Incident declaration and escalation:** Ensure the team promptly declares incidents and escalates its incident response to the appropriate levels.
- **Incident response reporting:** Craft reports that include an executive summary detailing who was involved, what happened, when and where it occurred, and why. Include recommendations, timelines, impacts, scope, and relevant evidence.
- **Communications:** Coordinate communications with legal teams, public relations, and customers. Handle media and regulatory reporting and involve law enforcement when necessary.
- **Root cause analysis:** Conduct a thorough root cause analysis to determine how the incident occurred and prevent future recurrences.
- **Lessons learned:** Document lessons learned to improve future incident responses.
- **Metrics and KPIs:** Monitor key metrics to detect, respond to, and remediate incidents. Track alert volumes to measure the effectiveness of incident management.

Get hands-on practical skills and experience using tools needed to perform tasks

To develop hands-on practical skills for the CompTIA CySA+ exam, here are some key tasks to practice based on the recommended CompTIA tools and their associated sub-tasks:

- **Packet capture and analysis:**
 - Practice capturing and analyzing network traffic using tools such as **Wireshark** and **tcpdump**.
- **Log analysis and correlation:**
 - Use an SIEM platform such as **Splunk**, **ELK**, or **Greylog** to collect, analyze, and correlate security logs.
 - Automate responses to incidents using **SOAR** tools.
- **Endpoint security:**
 - Implement and manage **Endpoint Detection and Response (EDR)** tools to monitor and secure endpoints.
- **DNS and IP reputation:**
 - Perform DNS and IP reputation lookups using tools such as **WHOIS** and **AbuseIPDB** to identify malicious actors.
- **File analysis:**
 - Analyze file contents using tools such as **Strings** and **VirusTotal** to detect malware.
- **Sandboxing:**
 - Use **Joe Sandbox** and **Cuckoo Sandbox** to execute suspicious files in an isolated environment and observe their behavior.
- **Network scanning and mapping:**
 - Conduct network scans using tools such as **Angry IP Scanner** and **Maltego** to identify active hosts and network topologies.
- **Web application security:**
 - Perform web application vulnerability assessments using tools such as **Burp Suite**, **Zed Attack Proxy (ZAP)**, **Arachni**, and **Nikto** to identify vulnerabilities.
- **Vulnerability scanners:**
 - Use **Nessus** and **OpenVAS** to scan systems for vulnerabilities and generate reports on potential weaknesses.
- **Debugging:**
 - Practice using debuggers such as **Immunity Debugger** and **GNU Debugger (GDB)** to analyze and troubleshoot software vulnerabilities.
- **Multipurpose tools:**
 - Explore various functionalities of **Nmap**, **Metasploit Framework (MSF)**, and **Recon-ng** for network reconnaissance and vulnerability exploitation.
- **Cloud infrastructure assessment:**
 - Assess cloud environments using tools such as **Scout Suite**, **Prowler**, and **Pacu** to evaluate security controls in platforms such as AWS, Azure, and GCP.

Prepare for performance-based questions with skills-based practice

When you take the CompTIA Security+ exam you'll need to answer skills-based performance-based exam questions (PBQs). Practicing job-related skills and is vital for effective exam preparations and passing this exam.

While preparing for the CompTIA CySA+ certification, you'll also need to know key terms and acronyms. For a comprehensive understanding of these terms and acronyms, refer to the **course glossaries** included in the [IBM Cybersecurity Analyst Professional Certificate](#) courses. These glossaries provide definitions and explanations of essential cybersecurity concepts and terminology.

Additionally, you can access the [CompTIA CySA+ Exam Objectives](#) PDF for a comprehensive list of acronyms used in exam questions.

Note: To open the PDF, right-click the document link and open the PDF document in a new tab.

Gather your study resources

To prepare effectively for the **CompTIA CySA+ exam**, gathering and organizing the necessary study resources is crucial. Here's a breakdown of what to focus on:

1. Lab setup

- **Equipment:** Set up workstations or laptops capable of running virtual machines (VMs).
- **Software:** Install critical tools such as **Wireshark**, **Kali Linux**, **Metasploitable**, **Nessus**, and **OpenVAS** for hands-on practice in network scanning, vulnerability analysis, and threat detection.
- **Cloud Access:** Ensure you have access to cloud environments such as **AWS**, **Azure**, or **GCP** for cloud infrastructure assessments.

2. CompTIA resources

- **CompTIA's official study** guide covers all exam objectives and includes practice questions, tips, and labs.
- **CompTIA eLearning tools:** Access to **CertMaster** or the **CompTIA Learning Center** provides interactive content and assessments.

3. Prior course exams

- If you've taken relevant courses (such as Network+ or Security+), review past exams to strengthen your foundational knowledge of security operations, network defense, and incident response.

4. Practice exams

- Use official CompTIA CySA+ practice tests on their website to familiarize yourself with the exam format.
- You can also use third-party practice exams from reputable sites to evaluate your readiness for the exam.

5. Online videos

- Many channels offer free video content covering CySA+ topics.
- You can also purchase or access CySA+ courses, including hours of video tutorials, labs, and quizzes to enhance your understanding.

6. Online communities

- Join online forums and communities to connect with other learners, share resources, and discuss exam strategies.

Create your study schedule

Developing a structured study schedule is essential for managing your time effectively. Here are some recommendations for the study schedule:

1. Set weekly study hours

- **Week 1-2:** Focus on core concepts of security operations and vulnerability management. Spend 10-12 hours per week reviewing concepts and watching videos.
- **Week 3-4:** Dedicate time to hands-on practice in your lab environment and cloud platforms. Aim for 8-10 hours of practical exercises.
- **Week 5-6:** Work on taking practice exams and reviewing missed questions. Study 8-12 hours per week.
- **Week 7-8:** Conduct final review and focus on weak areas. Include timed practice exams and spend 6-8 hours each week on revisions.

2. Use the study tools

- Break down the **CompTIA CySA+ exam objectives** into manageable parts for daily or weekly study sessions.
- Incorporate **videos and online tutorials** during off-peak hours to reinforce key topics.

Take practice exams

Regularly take practice tests to gauge your progress, identify weak areas, and adjust your study focus.

- Take **practice exams** at least twice a week during your study period. This course offers practice questions and scenarios that mirror the CySA+ exam format.
- Take the official CompTIA practice tests, which are highly recommended as they clearly represent what you'll see on exam day.

Summary

The CompTIA CySA+ exam focuses on cybersecurity analysis, emphasizing security operations, vulnerability management, incident response, and reporting. The exam focuses on four main domains:

1. **Security operations:** This domain covers system and network architecture concepts, analysis of malicious activity, threat intelligence, and process improvement in security operations.

2. **Vulnerability management:** This involves implementing scanning methods, analyzing vulnerability outputs, prioritizing vulnerabilities, recommending controls, and managing responses to vulnerabilities.
3. **Incident response and management:** This domain emphasizes understanding attack methodologies, executing incident response activities, and preparing for post-incident activities, including forensic and root cause analysis.
4. **Reporting and communication:** Effective reporting of vulnerabilities and incidents, communication with stakeholders, and documentation of lessons learned are key components in this domain.

Conclusion

Successfully passing the CompTIA CySA+ exam requires adequate study time and a comprehensive approach that includes domain knowledge, hands-on application and tool experience, knowledge of the acronyms you'll see when you take the exam, and exam practice. These technical study tips will help you fully prepare to correctly answer the questions and efficiently manage your test-taking time.



Skills Network